

RELAZIONE DI LABORATORIO

Analisi di un Attacco di Phishing e Social Engineering

Credential Harvesting ai danni di Account Instagram tramite Abuso di Piattaforma di Email Marketing (ConvertKit)

1. Introduzione

Il panorama delle minacce informatiche contemporanee non si esaurisce nella sola categoria del malware eseguibile: come evidenziato nel documento di riferimento fornito nell'ambito del percorso didattico, l'ingegneria sociale potenziata da tecniche di automazione rappresenta oggi uno dei vettori di attacco più efficaci e diffusi, in quanto agisce direttamente sul fattore umano anziché su vulnerabilità tecniche del sistema. Il phishing, in particolare, continua a costituire il principale punto di accesso iniziale per un numero significativo di violazioni di sicurezza su scala globale, complice la crescente sofisticazione grafica e comportamentale delle pagine di raccolta credenziali impiegate dagli attori di minaccia.

La presente relazione si colloca in continuità metodologica con una precedente esercitazione, nella quale era stato analizzato un campione appartenente alla famiglia degli infostealer (Vidar/Lumma Stealer), caratterizzato da un'infezione locale del sistema con conseguente esfiltrazione di dati mediante codice eseguibile. Il caso oggetto del presente studio si differenzia sostanzialmente da tale scenario: non è stato osservato alcun download o esecuzione di codice malevolo sul sistema della vittima, bensì un attacco di natura puramente percettiva e comportamentale, fondato sulla replica fedele dell'interfaccia di autenticazione della piattaforma Instagram e sulla successiva sottrazione delle credenziali eventualmente inserite dall'utente ignaro.

Si precisa, in via preliminare, che l'intera attività descritta nel presente elaborato è stata condotta in un contesto di laboratorio didattico, con finalità esclusivamente formative e di ricerca difensiva. Il link oggetto di analisi è stato aperto esclusivamente all'interno di un ambiente sandbox isolato e non è stata effettuata alcuna sottomissione reale di credenziali, né alcuna interazione con account appartenenti a soggetti terzi.

2. Obiettivi dell'Esercitazione

In coerenza con le linee guida metodologiche del percorso didattico, l'esercitazione si è posta i seguenti obiettivi formativi:

- **Ricostruire la catena di reindirizzamento** (redirect chain) impiegata dall'attaccante, dalla piattaforma di distribuzione dell'email fino alla pagina finale di raccolta credenziali.
- **Analizzare le tecniche di occultamento e di abuso di infrastruttura legittima** (in particolare l'impiego di un servizio di email marketing regolarmente operativo, ConvertKit, quale vettore di distribuzione e tracciamento).
- **Verificare l'assenza o la presenza di componenti malware** mediante osservazione dei processi di sistema e del comportamento del browser durante l'intera sessione di navigazione.
- **Analizzare il traffico di rete e le risoluzioni DNS generate**, al fine di identificare i domini e gli indirizzi IP coinvolti nella catena di attacco.
- **Mappare le tecniche osservate** secondo il framework MITRE ATT&CK, adattando la classificazione alla specificità di un attacco privo di payload eseguibile.
- **Confrontare criticamente il presente caso di studio con il precedente scenario malware-based**, al fine di evidenziare le differenze in termini di superficie di attacco, indicatori tecnici e strategie di rilevamento applicabili.
- **Proporre contromisure organizzative e tecniche** specificamente calibrate sul contrasto del credential phishing, in continuità con i principi di difesa (Zero Trust, MFA resistente al phishing) delineati nel documento di riferimento del corso.

3. Metodologia di Analisi

3.1 Ambiente di Esecuzione

L'analisi è stata condotta impiegando la piattaforma ANY.RUN, mediante apertura del collegamento (URL) oggetto di indagine all'interno di una macchina virtuale Windows 10 a 64 bit (build 10.0.19041), dotata di browser Google Chrome quale applicativo predefinito. Tale configurazione ha permesso l'osservazione realistica del comportamento della pagina di destinazione, incluso il rendering grafico dell'interfaccia fraudolenta e l'intera sequenza di richieste di rete generate durante la navigazione.

3.2 Approccio Metodologico

Diversamente dal caso di analisi malware, ove l'osservazione si concentra primariamente sul comportamento di processi ed eseguibili, l'analisi di un vettore di phishing richiede un approccio orientato principalmente:

- alla ricostruzione della catena di reindirizzamento HTTP (redirect chain analysis);
- alla verifica dell'autenticità del dominio di destinazione e dell'eventuale tecnica di typosquatting, domain spoofing o abuso di sottodomini legittimi;
- all'analisi visiva e strutturale della pagina (page similarity analysis), volta a determinare il grado di somiglianza con l'interfaccia originale imitata;
- alla verifica dell'assenza di componenti malevoli scaricati sul sistema, condotta mediante il medesimo strumentario impiegato nell'analisi malware (monitoraggio processi, file system, registro).

Il processo di analisi si è pertanto articolato nelle seguenti fasi operative:

Fase	Descrizione
1. Acquisizione dell'URL sospetto	Caricamento del collegamento nella sandbox interattiva
2. Osservazione del reindirizzamento	Tracciamento della sequenza di redirect HTTP fino alla destinazione finale
3. Analisi della pagina di destinazione	Ispezione visiva e strutturale della pagina renderizzata dal browser
4. Monitoraggio dei processi	Verifica dell'assenza di processi anomali o download di eseguibili
5. Analisi del traffico di rete e DNS	Ispezione delle connessioni stabilite e delle risoluzioni DNS effettuate
6. Correlazione con motore di reputazione	Verifica dell'assenza di alert Suricata/YARA (Network Threats)
7. Estrazione degli IoC	Raccolta sistematica di domini, IP e URL rilevanti
8. Mappatura MITRE ATT&CK	Classificazione delle tecniche di ingegneria sociale osservate

3.3 Limiti dell'Osservazione Automatica

Si evidenzia, in termini metodologici, come l'assenza di alert generati dal motore di reputazione automatico della sandbox (Network Threats: 0) non implichi l'assenza di rischio, bensì rifletta un limite intrinseco dei sistemi di rilevamento basati su firme e reputazione nei confronti di attacchi privi di componente malware. Tale osservazione costituisce, come si approfondirà nella Sezione 6, uno degli elementi di maggiore interesse didattico del presente caso di studio.

4. Executive Summary dei Risultati

Parametro	Valore Rilevato
Livello di minaccia	Medio-Alto
Verdetto sandbox (ANY.RUN)	No threats detected (nessun malware eseguibile rilevato)
Tipologia di attacco	Phishing / Scam via Email (Social Engineering)
Obiettivo primario dell'attacco	Sottrazione diretta di credenziali di accesso (username/password) di Instagram
Vettore di origine	Email inviata tramite piattaforma di email marketing ConvertKit (click.convertkit-mail2.com)
Piattaforma di analisi	ANY.RUN (Windows 10, build 10.0.19041)
Numero di processi generati	10 (esclusivamente processi legittimi di Google Chrome e servizi Windows)
Richieste HTTP osservate	3
Richieste DNS osservate	33
Alert di rete (Network Threats)	0

Come illustrato in Figura 1, la sessione di analisi si apre con il caricamento dell'URL di reindirizzamento tracciante (click.convertkit-mail2.com), il quale conduce, in tempi rapidi, alla visualizzazione di una pagina che replica fedelmente l'interfaccia di autenticazione di Instagram. Si segnala come, a differenza del caso di studio malware precedentemente analizzato — nel quale la sandbox aveva attribuito un punteggio massimo di pericolosità (100/100 Malicious) — la piattaforma di analisi automatica classifichi la presente sessione come priva di minacce tecniche rilevabili, a conferma della natura elusiva, rispetto ai tradizionali sistemi di rilevamento signature-based, degli attacchi di puro social engineering.

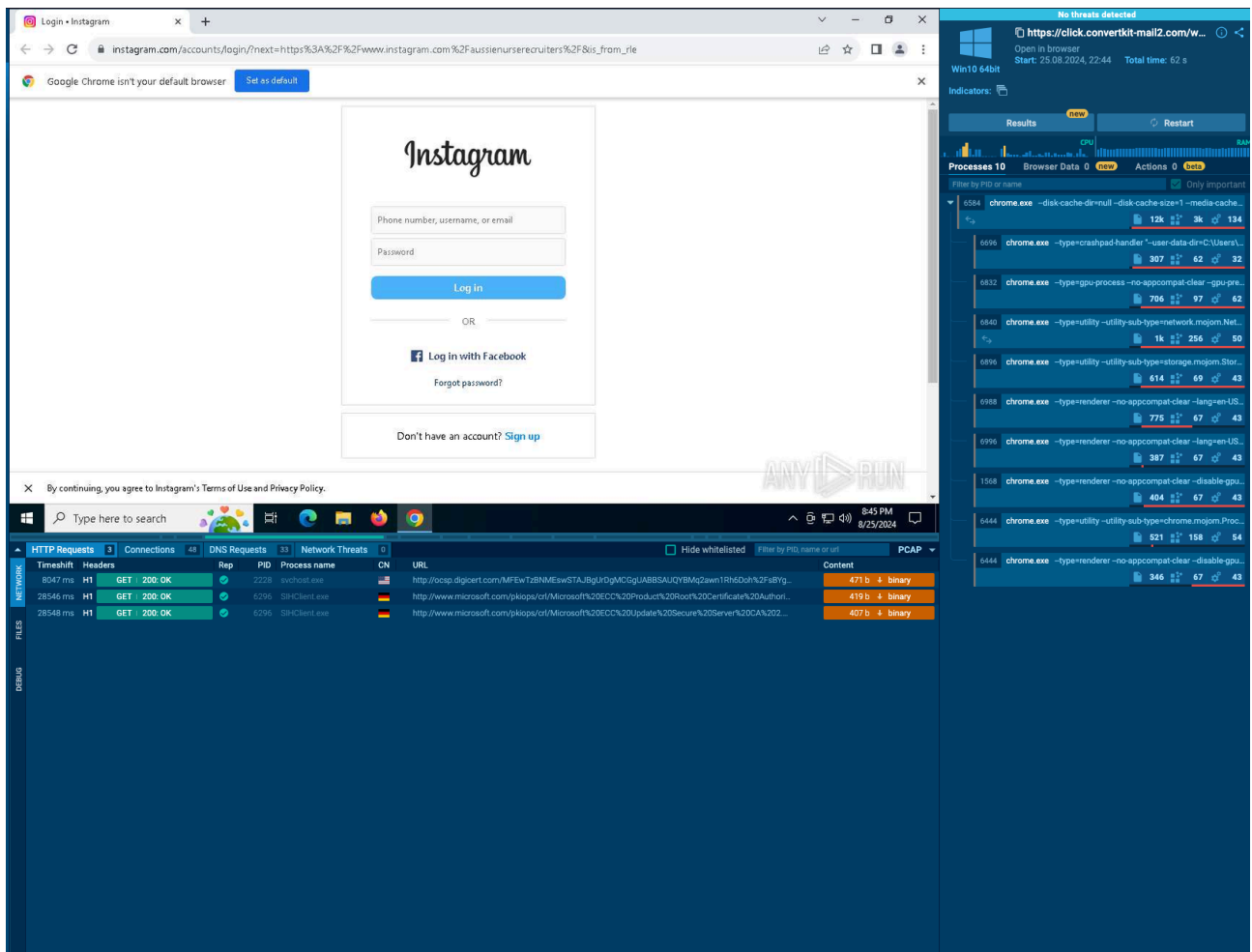


Figura 1 – Vista d'insieme della sessione di analisi ANY.RUN: a sinistra, la pagina di phishing renderizzata nel browser Chrome, con replica dell'interfaccia di login di Instagram; a destra, il pannello dei processi (10 in totale, tutti riconducibili a Chrome e a servizi di sistema legittimi) e l'indicazione del verdetto sandbox "No threats detected".

5. Analisi Tecnica Dettagliata della Catena di Attacco

5.1 Schema Sintetico della Catena di Attacco

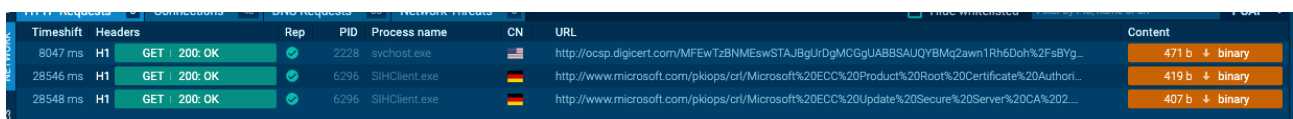
[Email Phishing] → [Redirect Tracking] → [Pagina Fake Instagram] → [Sottrazione Credenziali]
 ConvertKit Mail click.convertkit-mail2.com instagram.com/accounts/login/... Invio form dati

A differenza della kill chain analizzata nel caso di studio precedente — imperniata su esecuzione locale, process injection ed esfiltrazione tramite canale C2 — la catena di attacco qui ricostruita si sviluppa interamente all'interno del contesto applicativo del browser, senza alcuna interazione diretta con il file system o con processi di sistema estranei al normale funzionamento di Google Chrome.

5.2 Fase 1 – Vettore di Reindirizzamento e Tracciamento

Attributo	Valore
URL iniziale	https://click.convertkit-mail2.com/w...
Indirizzo IP del servizio	3.141.222.179 (Amazon Web Services – AWS)
Funzione	Tracciamento dell'apertura del link e reindirizzamento verso la pagina di destinazione

L'analisi ha evidenziato come l'attacco abbia origine da un messaggio di posta elettronica veicolato attraverso ConvertKit, piattaforma di email marketing legittima e ampiamente diffusa presso creator e piccole imprese. L'impiego di un servizio di terze parti regolarmente operativo, anziché di un'infrastruttura dedicata e riconducibile direttamente all'attaccante, costituisce una tecnica di occultamento efficace: il dominio click.convertkit-mail2.com, in quanto associato a un servizio legittimo, gode tipicamente di una reputazione neutra o positiva presso i sistemi di filtraggio antispam e i motori di reputazione DNS, riducendo sensibilmente la probabilità di blocco preventivo del messaggio o del link in esso contenuto (Figura 2).



Timeshift	Headers	Rep	PID	Process name	CN	URL	Content
8047 ms	H1 GET 200: OK	✓	2228	svchost.exe	US	http://ocsp.digicert.com/MFEWtZBNMEswSTAUBgUrdgMCGgUABBSAUQYBMq2awn1Rh6Doh%2Fs8Yg...	471 b ↓ binary
28546 ms	H1 GET 200: OK	✓	6296	SIHClient.exe	DE	http://www.microsoft.com/pkiops/crl/Microsoft%20ECC%20Product%20Root%20Certificate%20Autho...	419 b ↓ binary
28548 ms	H1 GET 200: OK	✓	6296	SIHClient.exe	DE	http://www.microsoft.com/pkiops/crl/Microsoft%20ECC%20Update%20Secure%20Server%20CA%202...	407 b ↓ binary

Figura 2 – Dettaglio delle richieste HTTP registrate durante la sessione, con evidenza del ridotto numero di chiamate dirette (3) rispetto al volume di connessioni di rete complessivo, a conferma della natura prevalentemente client-side e visuale dell'attacco.

5.3 Fase 2 – Piattaforma di Destinazione (Fake Instagram Login)

Attributo	Valore
Browser utilizzato	Google Chrome (chrome.exe)
URL di destinazione visibile	instagram.com/accounts/login/?next=https%3A%2F%2Fwww.instagram.com%2Faussienurserecreuters%2F&...

La pagina mostrata nel browser al termine della catena di reindirizzamento replica in maniera puntuale la schermata di accesso standard di Instagram, riproducendo fedelmente i campi “Phone number, username, or email” e “Password”, il pulsante di accesso, l'opzione di login tramite Facebook e i collegamenti secondari (“Forgot password?”, “Sign up”), come documentato in Figura 1. Tale accuratezza grafica è finalizzata a massimizzare la credibilità percepita dalla vittima e, conseguentemente, la probabilità di sottomissione delle proprie credenziali.

Di particolare rilievo analitico risulta la presenza, all'interno dell'URL, del parametro `next=`, il quale punta a uno specifico profilo (`aussienurserecreuters`). Tale elemento costituisce un indicatore tecnico significativo, poiché suggerisce l'esistenza di una campagna di phishing mirata (targeted phishing), verosimilmente correlata a un finto annuncio di reclutamento o a un'offerta di lavoro fittizia nel settore infermieristico australiano, tecnica di pretexting comunemente impiegata per aumentare la plausibilità del contesto e indurre la vittima a ritenere legittima la richiesta di autenticazione.

5.4 Fase 3 – Analisi dei Processi e Verifica dell'Assenza di Componenti Malevoli

Come riportato in Figura 3, l'osservazione dell'albero dei processi generati durante l'intera sessione ha evidenziato esclusivamente istanze legittime del processo `chrome.exe`, articolate secondo la consueta architettura multi-processo del browser (`renderer`, `GPU process`, `utility process`, `crashpad handler`), unitamente ai fisiologici processi di sistema Windows (`svchost.exe`, `SIHClient.exe`). Non è stato rilevato alcun processo con denominazione anomala o generata casualmente, né alcuna iniezione in processi legittimi di sistema (quali, ad esempio, `RegAsm.exe`, osservato invece nel caso di studio precedente), né infine alcuno script di rimozione o cancellazione (`cmd.exe` con comandi di self-deletion).

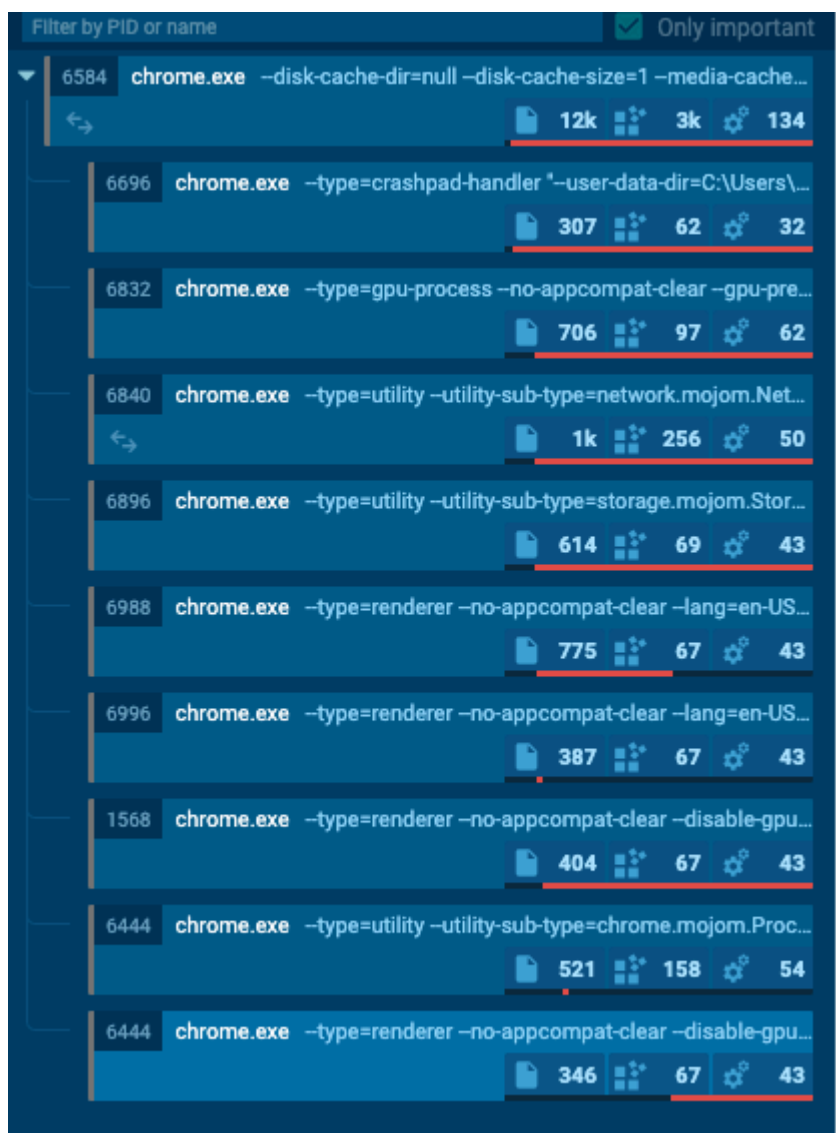


Figura 3 – Albero dei processi generati durante la sessione di analisi: tutte le istanze sono riconducibili a componenti standard dell'architettura multi-processo di Google Chrome, senza alcun indicatore di iniezione di codice o esecuzione di eseguibili estranei.

Tale riscontro conferma, sotto il profilo tecnico, che il vettore di attacco analizzato non prevede alcuna componente di compromissione locale del sistema, e che l'intero rischio associato risiede esclusivamente nell'eventuale inserimento volontario delle credenziali da parte dell'utente all'interno del form fraudolento.

5.5 Fase 4 – Analisi del Traffico di Rete e delle Risoluzioni DNS

5.5.1 Connessioni di Rete Stabiliate

L'analisi delle 48 connessioni di rete registrate (Figura 4) ha permesso di identificare i seguenti domini principali coinvolti nella sessione:

Dominio	IP / ASN	Funzione
click.convertkit-mail2.com	3.141.222.179 (AMAZON-02)	Tracciamento e reindirizzamento del link email

Dominio	IP / ASN	Funzione
www.instagram.com	157.240.0.174 (FACEBOOK)	Caricamento della pagina di login fraudolenta
static.cdninstagram.com	157.240.0.63 (FACEBOOK)	Caricamento asset grafici (loghi, stili, script)
www.facebook.com	157.240.0.35 (FACEBOOK)	Componente “Log in with Facebook” e servizi correlati
login.live.com	20.190.160.x (MICROSOFT-CORP-MSN-AS-BLOCK)	Servizio di autenticazione Microsoft (traffico di sistema, non correlato all'attacco)
content-autofill.googleapis.com	142.250.186.138 (GOOGLE)	Modulo di compilazione automatica di Google Chrome

HTTP Requests 3		Connections 48		DNS Requests 33		Network Threats 0				Hide whitelisted Filter by PID, domain, name or IP		PCAP
Timeshift	Protocol	Rep	PID	Process name	CN	IP	Port	Domain	ASN		Traffic	
BEFORE	UDP	✓	4	System	?	192.168.100.255	138	–	–		↑ 558 b ↓	–
BEFORE	TCP	✓	4436	svchost.exe	?	51.104.136.2	443	settings-win.data.microsoft.com	MICROSOFT-CORP-MSN-AS-BLOCK		No Data	
BEFORE	TCP	✓	608	RUXIMICS.exe	?	51.104.136.2	443	settings-win.data.microsoft.com	MICROSOFT-CORP-MSN-AS-BLOCK		No Data	
BEFORE	TCP	✓	2120	MoUserCoreWorker.exe	?	51.104.136.2	443	settings-win.data.microsoft.com	MICROSOFT-CORP-MSN-AS-BLOCK		No Data	
6226 ms	UDP	✓	6584	chrome.exe	?	239.255.255.250	1900	–	–		↑ 696 b ↓	–
6227 ms	TCP	?	6840	chrome.exe	?	3.141.222.179	443	click.convertkit-mail2.com	AMAZON-02		↑ 1 Kb ↓	6 Kb
6264 ms	TCP	?	6840	chrome.exe	?	66.102.1.84	443	accounts.google.com	GOOGLE		↑ 1 Kb ↓	7 Kb
6282 ms	TCP	?	6840	chrome.exe	?	157.240.0.174	443	www.instagram.com	FACEBOOK		↑ 28 Kb ↓	288 Kb
6913 ms	TCP	?	6840	chrome.exe	?	157.240.0.63	443	static.cdninstagram.com	FACEBOOK		↑ 639 b ↓	3 Kb
6917 ms	TCP	?	6840	chrome.exe	?	157.240.0.63	443	static.cdninstagram.com	FACEBOOK		↑ 607 b ↓	2 Kb
6919 ms	TCP	?	6840	chrome.exe	?	157.240.0.63	443	static.cdninstagram.com	FACEBOOK		↑ 607 b ↓	3 Kb
6921 ms	TCP	?	6840	chrome.exe	?	157.240.0.63	443	static.cdninstagram.com	FACEBOOK		↑ 607 b ↓	2 Kb
6923 ms	TCP	?	6840	chrome.exe	?	157.240.0.63	443	static.cdninstagram.com	FACEBOOK		↑ 4 Kb ↓	2 Mb
6925 ms	TCP	?	6840	chrome.exe	?	157.240.0.63	443	static.cdninstagram.com	FACEBOOK		↑ 581 b ↓	3 Kb
6929 ms	TCP	?	6840	chrome.exe	?	157.240.0.63	443	static.cdninstagram.com	FACEBOOK		↑ 787 b ↓	536 b
6932 ms	TCP	?	6840	chrome.exe	?	157.240.0.63	443	static.cdninstagram.com	FACEBOOK		↑ 639 b ↓	3 Kb
8029 ms	TCP	?	2228	svchost.exe	?	40.126.32.133	443	login.live.com	MICROSOFT-CORP-MSN-AS-BLOCK		↑ 5 Kb ↓	14 Kb
8038 ms	TCP	?	6840	chrome.exe	?	157.240.0.63	443	static.cdninstagram.com	FACEBOOK		↑ 2 Kb ↓	58 Kb
8041 ms	TCP	✓	3260	svchost.exe	?	40.113.110.67	443	client.wns.windows.com	MICROSOFT-CORP-MSN-AS-BLOCK		↑ 2 Kb ↓	4 Kb
8043 ms	TCP	✓	2228	svchost.exe	?	192.229.221.95	80	ocsp.digicert.com	EDGECAST		↑ 236 b ↓	737 b
8045 ms	TCP	?	6840	chrome.exe	?	157.240.0.35	443	www.facebook.com	FACEBOOK		↑ 1 Kb ↓	4 Kb
9126 ms	TCP	✓	6840	chrome.exe	?	142.250.186.138	443	content-autofill.googleapis.com	GOOGLE		↑ 1 Kb ↓	6 Kb
9130 ms	TCP	✓	4436	svchost.exe	?	51.104.136.2	443	settings-win.data.microsoft.com	MICROSOFT-CORP-MSN-AS-BLOCK		↑ 2 Kb ↓	8 Kb

Figura 4 – Tabella completa delle connessioni di rete stabilite durante la sessione, con evidenza del dominio di tracciamento ConvertKit e dei domini legittimi di Instagram/Facebook impiegati per il rendering della pagina fraudolenta.

Si osserva come la quasi totalità del traffico generato sia diretta verso infrastrutture legittime appartenenti a Meta (Facebook/Instagram) e Google, in quanto la pagina fraudolenta, per risultare visivamente credibile, carica effettivamente gli asset grafici (fogli di stile, font, loghi) direttamente dai server ufficiali di Instagram (static.cdninstagram.com), mentre soltanto la struttura HTML della pagina e la logica di raccolta del form risultano controllate dall'attaccante.

5.5.2 Risoluzioni DNS

L'ispezione delle 33 richieste DNS (Figura 5 e Figura 6) conferma il quadro sopra delineato, evidenziando la risoluzione sequenziale dei domini click.convertkit-mail2.com, www.instagram.com, static.cdninstagram.com e www.facebook.com, senza alcuna risoluzione verso domini di reputazione palesemente sospetta o servizi di Dynamic DNS, a differenza di quanto osservato nel caso di studio malware di riferimento.

HTTP Requests		3	Connections		48	DNS Requests	33	Network Threats		0	☐ Hide whitelisted		Filter by IP or domain	PCAP
Timeshift	Status		Rep	Domain				IP						
BEFORE	Responded		✓	settings-win.data.microsoft.com				51.104.136.2						
BEFORE	Responded		✓	google.com				172.217.16.206						
								3.141.222.179						
6205 ms	Responded		✓	click.convertkit-mail2.com				3.18.56.123						
								18.220.225.51						
6207 ms	Requested		✓	click.convertkit-mail2.com				IP Addresses not found						
6207 ms	Responded		✓	accounts.google.com				66.102.1.84						
6208 ms	Requested		✓	accounts.google.com				IP Addresses not found						
6209 ms	Responded		✓	www.instagram.com				157.240.0.174						
6209 ms	Requested		✓	www.instagram.com				IP Addresses not found						
6905 ms	Responded		✓	static.cdinstagram.com				157.240.0.63						
6906 ms	Requested		✓	static.cdinstagram.com				IP Addresses not found						
								40.126.32.133						
								 20.190.160.20						
								40.126.32.140						
								40.126.32.68						
8013 ms	Responded		✓	login.live.com				20.190.160.17						
								20.190.160.22						
								40.126.32.134						
								40.126.32.76						
8014 ms	Responded		✓	client.wms.windows.com				40.113.110.67						
8015 ms	Responded		✓	ocsp.digicert.com				192.229.221.95						
8015 ms	Responded		✓	www.facebook.com				157.240.0.35						
8016 ms	Requested		✓	www.facebook.com				IP Addresses not found						

Figura 5 – Sequenza delle richieste DNS registrate nella prima fase della sessione, con evidenza della risoluzione del dominio di tracciamento ConvertKit e dei successivi domini Instagram.

NETWORK

FILES

DEBUG

HTTP Requests3Connections48DNS Requests33Network Threats0

☐ Hide whitelisted

Filter by IP or domain

PCAP

Timeshift	Status	Rep	Domain	IP
8015 ms	Responded		www.facebook.com	174.127.66.170
8016 ms	Requested		www.facebook.com	157.240.0.35
				IP Addresses not found
				142.250.186.138
				142.250.185.138
				142.250.186.170
				142.250.184.234
				142.250.185.170
				142.250.185.202
				142.250.185.234
				142.250.181.234
				142.250.186.74
9114 ms	Responded		content-autofill.googleapis.com	216.58.212.170
				216.58.206.74
				142.250.186.42
				172.217.18.10
				142.250.186.106
				172.217.16.202
				216.58.206.42
				IP Addresses not found
				172.217.16.196
				IP Addresses not found
				27539 ms
28539 ms	Responded		www.microsoft.com	23.35.229.160
28540 ms	Responded		fe3scr.delivery.mp.microsoft.com	52.165.164.15
28541 ms	Responded		fe3scr.delivery.mp.microsoft.com	52.165.164.15

HTTP Requests	3	Connections	48	DNS Requests	33	Network Threats	0		Hide whitelisted	Filter by IP or domain	PCAP
Timeshift	Status	Rep	Domain	IP							
28541 ms	Responded	✓	fe3or.delivery.mp.microsoft.com	52.165.164.15							
29541 ms	Responded	✓	slscr.update.microsoft.com	20.12.23.50							
33347 ms	Responded	✓	www.facebook.com	157.240.0.35							
33347 ms	Requested	✓	www.facebook.com	IP Addresses not found							
33348 ms	Responded	✓	static.xx.fbcdn.net	157.240.0.6							
33348 ms	Requested	✓	static.xx.fbcdn.net	IP Addresses not found							
33349 ms	Responded	✓	facebook.com	157.240.0.35							
33349 ms	Requested	✓	facebook.com	IP Addresses not found							
				142.250.186.138							
				142.250.185.138							
				142.250.186.170							
				142.250.184.234							
				142.250.185.170							
				142.250.185.202							
				142.250.185.234							
				142.250.181.234							
				142.250.186.74							
				216.58.212.170							
				216.58.206.74							
				142.250.186.42							
				172.217.18.10							
				142.250.186.106							
				172.217.16.202							
				216.58.206.42							
34347 ms	Responded	✓	content-autofill.googleapis.com								
34347 ms	Requested	✓	content-autofill.googleapis.com	IP Addresses not found							
44655 ms	Responded	✓	settings-win.data.microsoft.com	51.104.136.2							

Figura 6 e Figura 7 – Prosecuzione del log delle risoluzioni DNS, a conferma dell'assenza di domini generati algebricamente (DGA) o di infrastrutture di comando e controllo, coerentemente con la natura non malware dell'attacco analizzato.

5.5.3 Assenza di Alert di Sicurezza di Rete

Diversamente dal caso di studio precedente, in cui il motore Suricata aveva generato otto alert distinti (incluso il rilevamento esplicito di una connessione TLS riconducibile a Lumma Stealer), la presente sessione non ha prodotto alcun alert di sicurezza di rete (Network Threats: 0). Tale circostanza, lungi dal rappresentare un'assenza di rischio, evidenzia un limite strutturale dei sistemi di rilevamento basati su firme e reputazione di rete nei confronti di attacchi che non presentano pattern di comunicazione anomali, in quanto il traffico generato è, dal punto di vista tecnico, indistinguibile da una normale sessione di navigazione verso i domini legittimi di Instagram e Facebook.

6. Confronto con il Caso di Studio Precedente (Malware vs. Phishing)

Al fine di evidenziare le differenze strutturali tra le due categorie di minaccia analizzate nel percorso didattico, si riporta di seguito una tabella comparativa tra il presente caso di studio e la precedente esercitazione, incentrata sull'analisi del campione infostealer Vidar/Lumma.

Parametro	Analisi Precedente (Vidar/Lumma)	Analisi Attuale (Instagram Phishing)
Punteggio sandbox	100/100 – Malicious	No threats detected
Natura dell'attacco	Malware / Trojan Infostealer	Phishing / Social Engineering
Azione sul sistema	Iniezione di codice, furto file in locale	Nessuna modifica locale al file system
Componente eseguibile	Presente (dropper, process hollowing, DLL dropping)	Assente
Rilevabilità automatica	Elevata (firme YARA/Suricata, punteggio massimo)	Ridotta (nessun alert automatico generato)
Superficie di rischio	Compromissione dell'intero endpoint	Furto delle sole credenziali inserite dall'utente
Fattore abilitante primario	Vulnerabilità tecnica / esecuzione di codice	Fattore umano (inganno percettivo)
Contromisura più efficace	Soluzioni EDR e Application Whitelisting	MFA resistente al phishing e formazione dell'utente

Tale confronto risulta di particolare interesse didattico in quanto dimostra come l'assenza di indicatori tecnici di compromissione non equivalga all'assenza di rischio: un attacco di phishing ben congegnato, pur non generando alcun alert nei sistemi di sicurezza automatizzati, può risultare altrettanto — se non maggiormente — dannoso rispetto a un'infezione malware tradizionale, in ragione della sua capacità di eludere sistematicamente i controlli tecnici basati su firme e di fare leva direttamente sul fattore umano.

7. Indicatori di Compromissione (IoC)

Ai fini della condivisione con la comunità di threat intelligence e dell'eventuale implementazione di regole di rilevamento (filtri antispam, DNS filtering, SIEM), si riporta di seguito la tabella riepilogativa degli Indicatori di Compromissione estratti nel corso dell'analisi.

7.1 Domini e Indirizzi IP Coinvolti

Tipologia	Indicatore	Ruolo
Dominio di tracciamento/redirect	click.convertkit-mail2.com	Piattaforma legittima abusata per distribuzione e tracciamento del link di phishing
Indirizzo IP di tracciamento	3.141.222.179 (AWS)	Hosting del servizio di reindirizzamento
URL di destinazione fraudolenta	instagram.com/accounts/login/?next=..aussienurserecreuters...	Pagina di raccolta credenziali (clone dell'interfaccia Instagram)

7.2 Elementi Distintivi della Campagna

Elemento	Descrizione
Target dichiarato	Account/profilo Instagram aussienurserecreuters
Presunto pretesto (pretexting)	Offerta di lavoro / reclutamento nel settore infermieristico (contesto australiano)
Obiettivo dell'attacco	Credenziali di accesso Instagram (username/email e password)

Si evidenzia come, a differenza del caso malware precedentemente analizzato, il presente scenario non produca IoC di tipo file-based (hash, percorsi file, nomi di processo), bensì esclusivamente indicatori di tipo network-based e comportamentale, coerentemente con la natura dell'attacco.

8. Mappatura delle Tecniche secondo il Framework MITRE ATT&CK

Sebbene il framework MITRE ATT&CK sia stato storicamente sviluppato con particolare focus sulle tecniche post-compromissione, esso include una specifica categoria di tecniche riconducibili alla fase di accesso iniziale tramite ingegneria sociale, pienamente applicabili al caso in esame.

Tattica	Tecnica	ID	Osservazione
Reconnaissance	Gather Victim Identity Information	T1589	Profilazione del target per la costruzione del pretesto di reclutamento
Resource Development	Acquire Infrastructure: Web Services	T1583.006	Abuso della piattaforma legittima ConvertKit per distribuzione e tracciamento
Initial Access	Phishing: Spearphishing Link	T1566.002	Email contenente link di reindirizzamento verso la pagina fraudolenta
Execution (lato vittima)	User Execution: Malicious Link	T1204.001	Apertura del link da parte dell'utente target
Credential Access	Phishing for Information	T1598	Raccolta diretta delle credenziali tramite form fraudolento
Defense Evasion (implicita)	Impersonation	T1656	Replica dell'identità visiva e del marchio Instagram

Nota metodologica: l'assenza di tecniche riconducibili alle tattiche Execution (in senso di esecuzione di codice), Persistence e Defense Evasion tecnica (ad es. process injection) conferma, anche sotto il profilo della classificazione standardizzata, la natura puramente ingegneristico-sociale dell'attacco, in continuità con quanto osservato nell'analisi comportamentale delle Sezioni 5 e 6.

9. Considerazioni Finali e Lezioni Apprese

L'esercitazione condotta ha permesso di sviluppare una comprensione approfondita delle dinamiche proprie di un attacco di phishing/credential harvesting, evidenziando come tale categoria di minaccia, pur presentando un profilo tecnico assai meno complesso rispetto a un'infezione malware strutturata, non risulti per questo meno pericolosa, bensì sfrutti un vettore di compromissione — il fattore umano — intrinsecamente più difficile da mitigare attraverso i soli controlli tecnologici.

Dal punto di vista metodologico, l'attività ha evidenziato l'importanza di integrare l'analisi automatizzata basata su sandbox e motori di reputazione con una valutazione critica e manuale del contesto, in quanto un verdetto di “No threats detected” non equivale, come dimostrato, all'assenza di rischio, ma riflette semplicemente l'assenza di indicatori tecnici rilevabili dai motori a firme. Tale osservazione costituisce, a giudizio di chi scrive, la lezione più rilevante appresa nel corso della presente esercitazione.

Sul piano didattico, l'esercizio ha permesso di consolidare competenze trasversali relative:

- alla ricostruzione e all'interpretazione di catene di reindirizzamento HTTP in un contesto di phishing;
- all'analisi critica dell'abuso di infrastrutture SaaS legittime (email marketing, hosting, servizi cloud) quale tecnica di elusione dei controlli di reputazione;
- alla mappatura di tecniche di ingegneria sociale secondo il framework MITRE ATT&CK, anche in assenza di indicatori di compromissione tradizionali;
- alla comparazione metodologica tra minacce malware-based e minacce social-engineering-based, con conseguente adattamento delle rispettive strategie di rilevamento e mitigazione.

Il confronto diretto con il caso di studio precedente (Sezione 6) rafforza, in particolare, la consapevolezza circa la necessità di un approccio di difesa multilivello (defense in depth), nel quale controlli tecnici avanzati (EDR, IDS/IPS) e controlli orientati al fattore umano (MFA resistente al phishing, formazione, procedure di segnalazione) risultino tra loro complementari e non sostitutivi.

10. Conclusioni

L'analisi condotta ha consentito di caratterizzare in maniera rigorosa un vettore di attacco rappresentativo delle moderne campagne di phishing orientate al furto di credenziali social, confermando come l'abuso di infrastrutture legittime di terze parti e la replica accurata dell'interfaccia utente di servizi ampiamente diffusi costituiscano oggi tecniche standard nell'arsenale degli attori di minaccia orientati all'ingegneria sociale su larga scala.

Il caso di studio dimostra, in termini generali, come la sicurezza informatica non possa fondarsi esclusivamente su controlli tecnici automatizzati, per quanto sofisticati: l'assenza di alert generati dal motore di analisi sandbox nel presente scenario — a fronte di un rischio concreto e potenzialmente critico di compromissione dell'identità digitale della vittima — dimostra empiricamente i limiti intrinseci di un approccio di difesa fondato unicamente su firme e reputazione. Solo l'adozione integrata di autenticazione resistente al phishing, controlli avanzati a livello di gateway email e programmi strutturati di formazione del personale consente di colmare tale divario, spostando il baricentro della difesa dal solo endpoint tecnico alla resilienza complessiva del sistema socio-tecnico costituito dall'organizzazione e dai suoi utenti.

In una prospettiva più ampia, il presente caso di studio, letto in continuità con la precedente esercitazione sul malware Vidar/Lumma, conferma quanto affermato nel documento di riferimento circa la natura della cybersecurity quale processo continuo e multidimensionale: la capacità di un'organizzazione — o del singolo individuo — di resistere a minacce eterogenee, tecniche e comportamentali, dipende dall'integrazione sinergica tra tecnologia, consapevolezza umana e procedure strutturate di risposta, autentici pilastri di una postura di sicurezza realmente resiliente di fronte all'evoluzione incessante delle tecniche offensive.

Relazione redatta a fini didattici nell'ambito di un'esercitazione di laboratorio in sicurezza informatica. L'attività descritta è stata condotta esclusivamente in ambiente sandbox isolato, senza alcuna sottomissione reale di credenziali né interazione con account, sistemi di produzione o infrastrutture appartenenti a soggetti terzi.